4-й участник. Как заранее защититься от DoS/DDoS-атаки. Исторические примеры и общий вывод

Моя часть посвящена не самой атаке, а тому, как заранее снизить риск и что показывают реальные крупные случаи DDoS-атак. Важно понимать, что полностью исключить DDoS-атаку почти невозможно. Если злоумышленник направит на сайт или сервер огромный объём трафика, сам факт попытки атаки предотвратить нельзя. Но можно сделать так, чтобы атака не вывела сервис из строя или чтобы простой был минимальным.

Главный принцип защиты от DDoS — не ждать атаки, а заранее строить инфраструктуру так, чтобы она могла выдерживать резкие скачки нагрузки. Для этого используют несколько уровней защиты.

Первое — это защита на уровне сети. Сайт или сервис не должен напрямую принимать весь входящий трафик на один сервер. Лучше использовать CDN, балансировщики нагрузки и DDoS-защиту у провайдера. CDN распределяет запросы между разными узлами, а специализированная DDoS-защита фильтрует подозрительный трафик ещё до того, как он дойдёт до основного сервера.

Второе — резервирование. Если весь проект работает на одном сервере, это слабое место. При атаке он может перестать отвечать. Поэтому серьёзные сервисы используют несколько серверов, резервные каналы связи, резервный DNS и возможность быстро переключить трафик на другую площадку. Особенно важен DNS, потому что при атаке на DNS-провайдера пользователи могут потерять доступ к сайтам даже тогда, когда сами сайты технически работают.

Третье — настройка фильтрации. Нужно заранее ограничивать подозрительные запросы, вводить rate limiting, блокировать аномальную активность, использовать Web Application Firewall, проверять логи и отслеживать необычный рост трафика. Например, если с одного диапазона адресов резко приходит слишком много одинаковых запросов, система должна автоматически снижать приоритет такого трафика или блокировать его.

Четвёртое — мониторинг. DDoS-атака опасна тем, что развивается быстро. Поэтому администратор должен видеть метрики в реальном времени. Важны не только загрузка процессора и памяти, но и количество запросов в секунду, число соединений, география трафика, ошибки 5xx, задержки ответа сервера. Если мониторинг настроен заранее, атаку можно заметить в первые минуты.

Пятое — план реагирования. У организации должен быть заранее прописанный порядок действий. Кто связывается с хостинг-провайдером, кто включает аварийные правила

фильтрации, кто проверяет доступность сайта, кто сообщает пользователям о проблеме. Во время атаки нельзя тратить время на выяснение, кто за что отвечает.

Шестое — защита своих устройств. Многие DDoS-атаки выполняются через ботнеты, то есть сети заражённых устройств. В них могут входить камеры, роутеры, видеорегистраторы и другие IoT-устройства. Поэтому даже обычный пользователь должен менять стандартные пароли, обновлять прошивки роутеров, отключать ненужный удалённый доступ и не оставлять устройства открытыми в интернет. Это снижает вероятность того, что его техника станет частью чужой атаки.

Теперь приведу несколько известных исторических примеров.

Один из самых известных случаев произошёл в 2007 году в Эстонии. Тогда атакам подверглись сайты государственных органов, банков, СМИ и других организаций. Этот случай часто рассматривают как один из первых крупных примеров кибератаки против цифровой инфраструктуры целого государства. Атаки включали DoS и DDoS-методы, спам, перегрузку сайтов и другие формы давления на инфраструктуру. После этого Эстония усилила киберзащиту, а в Таллине позднее был создан Центр передового опыта НАТО по кибероборону.

В 2016 году произошла крупная атака на сайт журналиста Брайана Кребса KrebsOnSecurity. По данным самого KrebsOnSecurity, атака была необычна тем, что была связана не с классическим отражением через DNS, а с огромной сетью взломанных устройств. Это был важный сигнал для всей отрасли: обычные камеры, роутеры и видеорегистраторы могут использоваться как оружие в DDoS-атаках.

В том же 2016 году была атака на хостинг-провайдера OVH. По данным Cloudflare, атаки Mirai временно нарушали работу крупных сервисов, включая OVH, Dyn и KrebsOnSecurity; OVH сообщал об атаках свыше 1 Тбит/с. Последствие было серьёзным: стало понятно, что небезопасные IoT-устройства могут создавать трафик уровня крупных интернет-магистралей.

Особенно известна атака на DNS-провайдера Dyn 21 октября 2016 года. Dyn обслуживал DNS для множества крупных сайтов. Когда атаковали его инфраструктуру, проблемы возникли у Twitter, Spotify, Reddit, SoundCloud и других сервисов. Dyn сообщал, что атака была высокораспределённой и включала десятки миллионов IP-адресов. Главный урок этой атаки заключается в том, что DNS — критическая точка отказа. Даже если сайт работает, пользователи не смогут открыть его, если не работает система доменных имён.

В 2018 году произошла атака на GitHub. Она достигла пика 1,35 Тбит/с и использовала усиление через memcached-серверы. GitHub сообщил, что атака была обнаружена и смягчена в течение нескольких минут, а трафик был перенаправлен через DDoS-защиту.

Это хороший пример того, что заранее подготовленная инфраструктура и внешний сервис фильтрации могут спасти даже при очень мощной атаке.

В 2023 году Google Cloud сообщил о DDoS-атаках нового типа через HTTP/2 Rapid Reset. Самая крупная атака достигала 398 миллионов запросов в секунду. Это уже не просто перегрузка канала трафиком, а атака на уровень приложения, где злоумышленник пытается заставить сервер обрабатывать огромное количество запросов. Google связал эту волну атак с особенностями HTTP/2 и подчеркнул необходимость защиты не только на сетевом, но и на прикладном уровне.

В отчёте Cloudflare за третий квартал 2025 года также описаны гиперобъёмные атаки, связанные с ботнетом Aisuru. Cloudflare сообщал о DDoS-атаках до 29,7 Тбит/с и 14,1 млрд пакетов в секунду. Это показывает, что масштаб атак продолжает расти, а защита должна быть автоматизированной, потому что вручную реагировать на такие объёмы уже невозможно.

Общий вывод такой. DoS и DDoS-атаки опасны не тем, что они обязательно взламывают данные, а тем, что они делают сервис недоступным. Для банка это может означать остановку онлайн-операций, для магазина — потерю заказов, для СМИ — невозможность публиковать новости, для государства — удар по доверию граждан к цифровым сервисам.

Главная защита — это подготовка до атаки. Нужно использовать CDN, DDoS-фильтрацию, резервные серверы, резервный DNS, мониторинг, ограничение подозрительных запросов и заранее прописанный план реагирования. Исторические примеры показывают, что выигрывает не тот, кого никогда не атакуют, а тот, кто заранее построил инфраструктуру так, чтобы атака не стала катастрофой.